# 〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.29(목)

## ■ 활동 날짜 및 참여 조원

· 날짜: 2026-10-29(목), 개별 작업 + Notion 작업 보고서 공유

· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

## ■ 오늘의 목표

· AI-XDR 2차 지능형 위협 판정 엔진(NVIDIA NIM) 무응답·타임아웃 문제 근본 해결

· pfSense 자동 차단 피드(Cron) 동작 여부 전수 재점검

· 사내 챗봇 AI 보안 계층(NeMo Guardrails) 도입

· AI-XDR 자동 대응 체계를 수동 승인 중심으로 재정리

## ■ 조원별 활동 내역

### ▶ 진혜정 (자동화·n8n·상황판)

· 전달받은 Cloudflare `security-audit-skill` 보안 감사 결과(CRITICAL 1건·MEDIUM 2건) 수정에 착수했다가, 홍주형이 이미 같은 항목을 팀 저장소(stulss/nexus-work)에 전부 반영·커밋해 둔 것을 뒤늦게 발견 — 중복 수정분은 되돌리고, 제 포크(ginye28/nexus-work)가 팀 저장소보다 5일(78개 파일·1만 3천여 줄) 뒤처져 있던 것을 확인해 최신으로 동기화

· 사내 챗봇 앞단에 NeMo Guardrails 통합을 맡았으나, 실제 `nemoguardrails` 패키지가 langchain·pandas·numpy·annoy 등 80개 패키지를 끌고 오고 프로젝트가 쓰는 Python 3.14 환경에서 네이티브 빌드(annoy·watchdog)가 실패하는 것을 직접 설치 검증 후 확인 → 새 의존성 없는 경량 자체 구현(`app/guardrails.py`)으로 대체

· 기존 R2 탐지(`prompt_injection.py`)는 그대로 두고 그 다음 단계로만 연결 — 문장 중간 삽입형 무시 시도·역할극식 탈옥 유도(개발자 모드, DAN 등)만 추가로 차단, 신규 이벤트(`guardrails_block`)로 R2 로그와 분리해 기록

· 신규 단위 테스트 20건 작성(공격 패턴 7종 차단 확인 + 기존 R2 테스트의 "교육적 질문" 8종이 안 막히는 것까지 교차 확인), 전체 1,569개 테스트 정상 수집 확인 후 커밋·포크 푸시

### ▶ 홍주형 (웹·DB 하드닝)

· AI-XDR 판정이 전부 더미 폴백(REVIEW_REQUIRED, 0점)으로만 떨어지는 원인을 추적 — 기존 설정된 NVIDIA NIM 모델(meta/llama-3.2-11b-vision-instruct)이 무응답 타임아웃(30초 초과)을 일으키는 것을 확인

· 계정에서 접근 가능한 NVIDIA NIM 모델 84개를 전수 벤치마킹해 2초대 응답·엄격한 JSON 스키마 준수·자연스러운 한국어 사유 생성이 되는 minimaxai/minimax-m3.1-flash로 교체, 타임아웃 허용치를 60초로 확대, `.env`·`app/config.py`·`app/ai_xdr.py` 기본 모델을 일괄 동기화

· 실서버에서 SQL Injection 15회 주입으로 실제 공격 판정 검증 — 85점(악성) 판정, 신뢰도 0.980, 차단 조치 권장, 한국어 사유 정상 생성까지 확인

· AI 호출 지연 중 DB 커넥션이 먼저 끊겨 발생하던 HTTP 500(InterfaceError)을 방어 코드로 차단

· 화면 반분할(960px) 환경에서 좌측 메뉴 실종·헤더 2줄 꺾임으로 보안 대시보드 카드와 겹치던 문제 해결, AI-XDR 콘솔 카드형 뷰·DEFCON 위협 레벨 바·원클릭 퀵 필터 추가, 인라인 스크립트를 CSP 준수 정적 모듈(xdr.js)로 분리

· 시스템 전반 시간 표기를 KST로 통일, 브라우저 기본 `/favicon.ico` 요청으로 인한 404 로그 노이즈 차단

▶ 이시헌 (네트워크)

· 변경 없이 조회만으로 pfSense 설정 전체 점검 — WAN 차단 룰(GeoBlock·XDR_BLOCKED_IPS·NEXUS_AUTO_BLOCK)이 모든 Allow 룰보다 상단에 있어 우회 위험 없음, Anti-Lockout Rule 활성 상태, WebGUI는 HTTPS 전용이며 WAN 쪽에 GUI 허용 룰 자체가 없다는 점(허용 룰 부재로 막혀 있음)까지 확인해 공유 문서로 정리

· 새로 등록한 테스트 IP(203.0.113.101)가 pfSense에 반영되지 않는 문제를 조사해 Cron이 5분마다 실행은 되지만 매번 즉시 Fatal error로 죽고 있던 것을 발견 — 원인은 `require_once`가 상대경로(globals.php)라 CLI 실행 컨텍스트에서 실패했고, 절대경로로 고치는 과정에서도 실제 파일명이 globals.inc인데 globals.php로 잘못 가정해 두 번째 시도도 실패했던 것 — 최종적으로 `/etc/inc/globals.inc` 절대경로로 수정해 정상 동작(EXIT:0) 확인, Cron 주기도 5분에서 pfSense GUI 최소 단위인 1분으로 단축

· 모든 차단이 만료돼 피드가 완전히 비면 `process_alias_urltable()`의 안전장치 때문에 pfSense 테이블이 영구적으로 안 비워지는 구조적 허점을 발견 — HTTP 200+빈 바디를 "의도된 빈 상태"로 판단해 강제로 테이블을 비우도록 스크립트 개선·검증 완료

▶ 김태빈 (탐지)

· AI-XDR IP 대응을 자동 차단이 아닌 관리자 수동 승인 흐름으로 정리 — 일반 승인 제거, 차단 관련 버튼 문구 정리, 기존 80점 자동 기준 제거

· NVIDIA provider 설정 전달·`xdr_ai_failure` 진단 확인 — R8 탐지가 AI-XDR 처리까지는 진행되지만 NVIDIA 응답 타임아웃이 REVIEW_REQUIRED/0점/신뢰도 0 폴백으로 이어지는 직접 원인임을 독립적으로 확인(홍주형의 모델 교체 조치와 같은 근본 원인을 서로 다른 경로로 확인한 것)

· AI-XDR 화면의 시간 표시를 KST로 맞추고 판정·오류 안내를 한국어화

· pfSense 연동(blocked_ips → TXT feed → XDR_BLOCKED_IPS)과 TTL/갱신 흐름을 확인하는 준비 단계만 진행 — 실제 IP 차단·계정 잠금·Discord 발송·pfSense 설정 변경은 수행하지 않음

## ■ 조원별 의견 및 제안 사항

· 홍주형: 클라우드 LLM 제공사의 특정 모델이 예고 없이 응답 지연을 겪을 수 있으므로, 타임아웃 처리만으로 끝내지 않고 계정 권한·응답성을 전수 점검해 가장 안정적인 모델로 빠르게 전환하는 유연성이 필요하다는 것을 체감

· 이시헌: Cron이 "실행은 되는데 매번 바로 죽는" 상태는 로그를 직접 안 보면 "정상 작동 중"으로 착각하기 쉽다는 것을 재확인 — 자동화 스크립트는 주기 실행 여부뿐 아니라 실제 종료 코드까지 확인해야 함

· 김태빈: AI-XDR 자동 대응을 관리자 수동 승인으로 되돌린 결정이, NVIDIA 모델 불안정성이 완전히 해소되기 전까지는 더 안전한 운영 방향이라는 데 공감

· 진혜정: 작업을 시작하기 전에 팀 저장소 최신 상태를 먼저 확인하지 않아 하루치 작업을 다른 조원과 중

복으로 할 뻔한 것을 겪음 — 앞으로는 작업 착수 전 `stulss/nexus-work` 기준 동기화를 먼저 확인하기로

## ■ 회의 결과 및 결정 사항

1. AI-XDR 2차 판정 모델은 minimaxai/minimax-m3.1-flash로 표준 전환 확정(.env·config.py·ai_xdr.py 전부 동기화 완료)

2. AI-XDR IP 자동 차단은 당분간 중단하고 관리자 수동 승인 흐름으로 운영하기로 확정(80점 자동 기준 제거)

3. pfSense 자동 반영 Cron 주기는 1분으로 단축 확정, 빈 피드 상태는 강제로 테이블을 비우는 방식으로 확정

4. 사내 챗봇 보안 계층은 실제 NeMo Guardrails 패키지 대신 경량 자체 구현(`app/guardrails.py`)으로 확정 — 홍주형의 회고록에 "향후 계획"으로 남아 있던 항목을 같은 날 안에 완료

## ■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황

- AI-XDR NVIDIA 모델 타임아웃 문제를 근본 원인까지 규명하고 안정적인 모델로 교체, 실공격(SQLi) 판정까지 검증 완료
- pfSense Cron 자동화의 두 가지 구조적 버그(실행 즉시 죽는 문제, 빈 피드 시 미제거 문제)를 모두 발견·수정
- 사내 챗봇 보안 계층(Guardrails) 신규 도입 완료
- 반응형 UI(화면 반분할 대응) 전면 개편, KST 시간 통일

· 어려운 점

1. 포크가 팀 저장소보다 며칠 뒤처진 상태로 작업을 시작해 중복 수정이 발생할 뻔함 — 동기화 확인 절차 부재가 원인
2. 외부 클라우드 AI 제공자(NVIDIA NIM)의 특정 모델이 예고 없이 응답 지연을 일으켜 탐지 파이프라인 전체가 폴백 상태로 빠지는 취약점이 있었음
3. pfSense Cron 버그는 로그를 직접 열어보기 전까지는 "정상 실행 중"으로 보여 발견이 늦어질 뻔함

## ■ 향후 활동 계획 및 역할 분담

· NVIDIA provider 응답 정상 여부와 운영 코드 반영 상태 지속 확인(김태빈)

· 관리자 차단 승인 후 15분 등록·만료 흐름 검증(김태빈)

· pfSense feed/Alias 연동 준비 단계를 실제 연동 검증으로 이어가기(김태빈·이시현)

· 비상 주말/야간 모드 시 고위험 IP 자동 등록 파이프라인 지속 모니터링(홍주형)

· 감사 로그 대시보드 시간대별 위협 추이 시각화 차트 검토(홍주형)

· VULN-FINDINGS.md의 needs_validation 3건(internal API 토큰 평문 전달 여부 등) 팀 논의(전체)

· 심야 시간대(00:00~05:00 KST)에 R7 재검증(진혜정)

## ■ 증거 자료

· 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/29) 페이지

- 진혜정 - 10/29 작업 / 2026-10-29_NEXUS_WORK_개발_회고록(홍주형) / 10/29일 작업 보고서(이시현) / 2026-10-29 작업 기록(김태빈, 개인 워크스페이스)

· GitHub: ginye28/nexus-work main 브랜치, 커밋 7aee5c6(feat(ai): add lightweight guardrail layer for chat input)